

**SIEM na prática:
Monitoramento, Risco
e Governança em um
Laboratório
Controlado**



Ágata Czkut

Projeto:

Homelab SIEM + GRC

Autora:

Ágata Lilian Czkut Barbosa Rosa

Área:

Cibersegurança | Blue Team | SOC | GRC

Ferramentas utilizadas:

- Wazuh
- Oracle VM VirtualBox
- Kali Linux
- Ubuntu Server
- Nmap
- Hydra

1- INTRODUÇÃO:

A crescente dependência de ambientes digitais exige que organizações adotem mecanismos capazes de identificar, correlacionar e responder a eventos de segurança de forma estruturada.

Nesse contexto, soluções de SIEM (Security Information and Event Management) desempenham papel estratégico ao centralizar logs, detectar comportamentos suspeitos e apoiar decisões de segurança baseadas em evidências.

Este projeto teve como objetivo desenvolver um ambiente laboratorial de cibersegurança com foco em monitoramento de eventos, correlação de logs e aplicação prática de conceitos de Governança, Risco e Compliance (GRC)

Foi implementado um homelab utilizando o Wazuh como plataforma SIEM, integrado a máquinas virtuais com funções específicas de monitoramento, análise e simulação de atividades ofensivas.

Durante os testes, foram simuladas tentativas de autenticação via SSH, possibilitando validar a capacidade de detecção, análise de eventos e correlação com cenários reais de risco em segurança da informação.

2- OBJETIVO:

Implementar um ambiente laboratorial de monitoramento de segurança capaz de detectar comportamentos suspeitos em sistemas Linux, correlacionando eventos técnicos com princípios de gestão de risco, controles de segurança e práticas de Governança, Risco e Compliance (GRC).

O projeto buscou unir a perspectiva operacional de um ambiente SOC com a visão estratégica de proteção de ativos, continuidade operacional e redução de exposição a ameaças.

3- ARQUITETURA DO AMBIENTE:

Servidor SIEM:

- Ubuntu Server = Wazuh

Função: coleta, indexação, correlação e visualização de eventos.

Máquina ofensiva:

- Kali Linux

Função: simulação de atividades ofensivas e geração de telemetria.

Ferramentas utilizadas:

- Nmap → reconhecimento de serviços
- Hydra → simulação de autenticação repetida

Infraestrutura implementada:

O ambiente laboratorial foi desenvolvido utilizando Oracle VM VirtualBox como plataforma de virtualização, composto por duas máquinas virtuais com funções complementares de monitoramento e simulação.

3.1 Servidor de Monitoramento:

Ubuntu Server + Wazuh

São responsáveis pela coleta centralizada de logs, correlação de eventos de segurança, indexação de dados, visualização de alertas e investigação de incidentes.

3.2 Máquina de Simulação:

Kali Linux

Responsável pela simulação de atividades ofensivas controladas, validação de exposição de serviços e geração de eventos para análise no SIEM.

4- METODOLOGIA:

1. Validação de superfície exposta:

Inicialmente foi realizada a validação da superfície de ataque do host monitorado por meio de Nmap, identificando a porta 22/TCP aberta com o serviço SSH ativo. Essa etapa confirmou a existência de um serviço remotamente, permitindo a continuidade dos testes de autenticação controlada.



```
(agata@kali)-[~]
$ nmap -p 22 192.168.29.133
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-07 03:17 -03
Nmap scan report for 192.168.29.133
Host is up (0.00091s latency).

PORT      STATE SERVICE
22/tcp    open  ssh

Nmap done: 1 IP address (1 host up) scanned in 0.13 seconds

(agata@kali)-[~]
$
```

Figura 1- Identificação do serviço SSH exposto e validação da porta 22 utilizando Nmap.

2. Simulação de autenticação:

Após a execução dos testes controlados de autenticação, o ambiente monitorado registrou múltiplos eventos relacionados a falhas de login via SSH. O Wazuh correlacionou automaticamente os registros, identificando padrões como tentativas repetidas de autenticação, excesso de tentativa e falhas no módulo PAM, permitindo a associação entre atividade técnica e risco operacional.

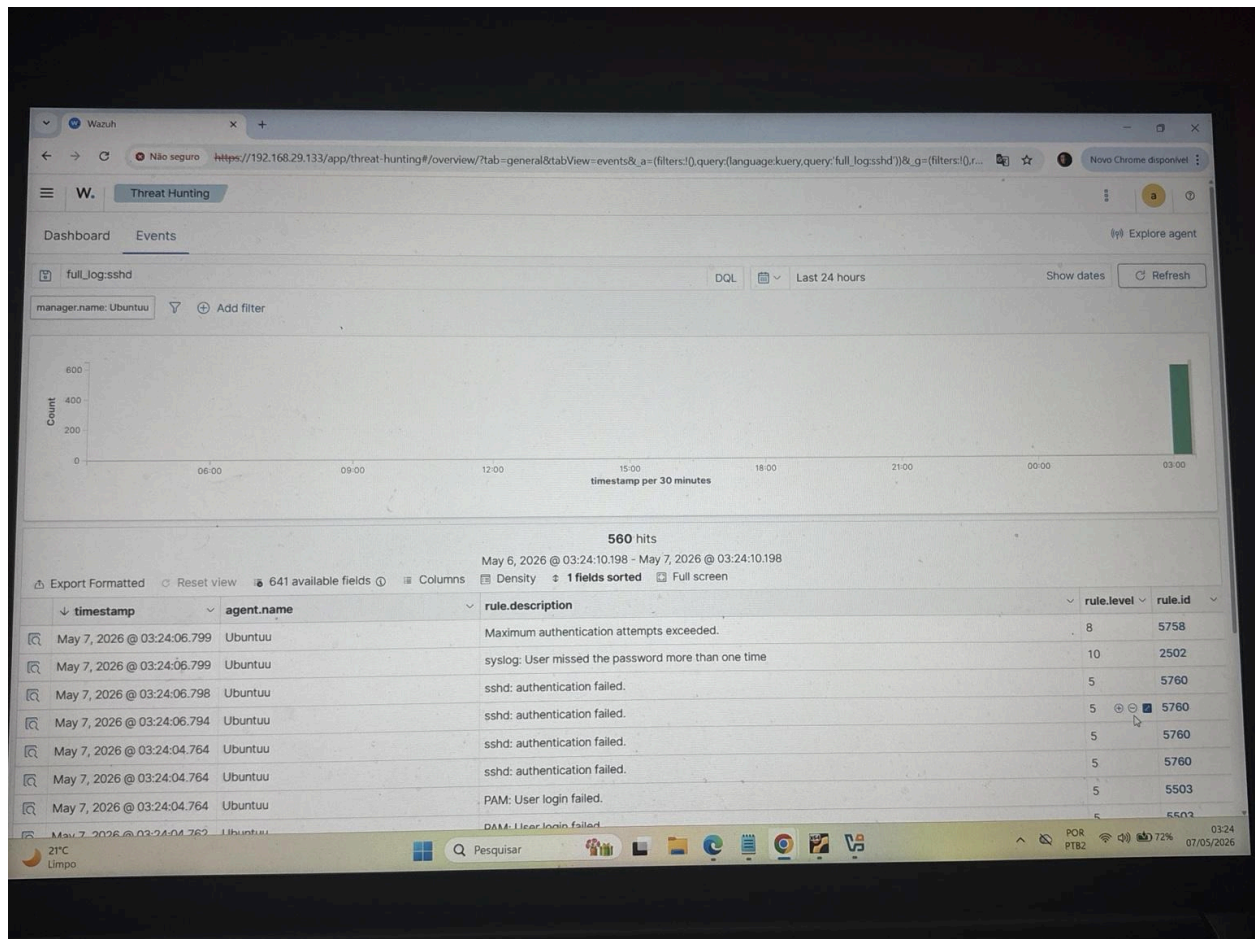


Figura 2 - Detecção e correlação de eventos de falha de autenticação SSH detectados pelos Wazuh durante uma simulação controlada.

3. Análise de Risco e Correlação com GRC:

A partir dos eventos identificados pelo ambiente SIEM, foi realizada a análise do cenário sob a perspectiva de Governança, Risco e Compliance (GRC).

As múltiplas falhas de autenticação via SSH, indicaram uma possível tentativa de acesso não autorizado, evidenciando exposição relacionada a credenciais privilegiadas e controles de autenticação remota.

Sob a ótica de gestão de risco, o evento foi correlacionado com:

Possíveis impactos relacionados:

- Comprometimento de contas administrativas.
- Interrupção operacional por acesso indevido.
- Exposição de ativos críticos de infraestrutura.
- Movimentação lateral dentro do ambiente.

Controles relacionados:

- **International Organization for Standardization ISO 27001** — gestão de controles de segurança
- **International Organization for Standardization ISO 27002** — controles de autenticação e acesso
- **International Organization for Standardization ISO 27005** — tratamento e avaliação de riscos

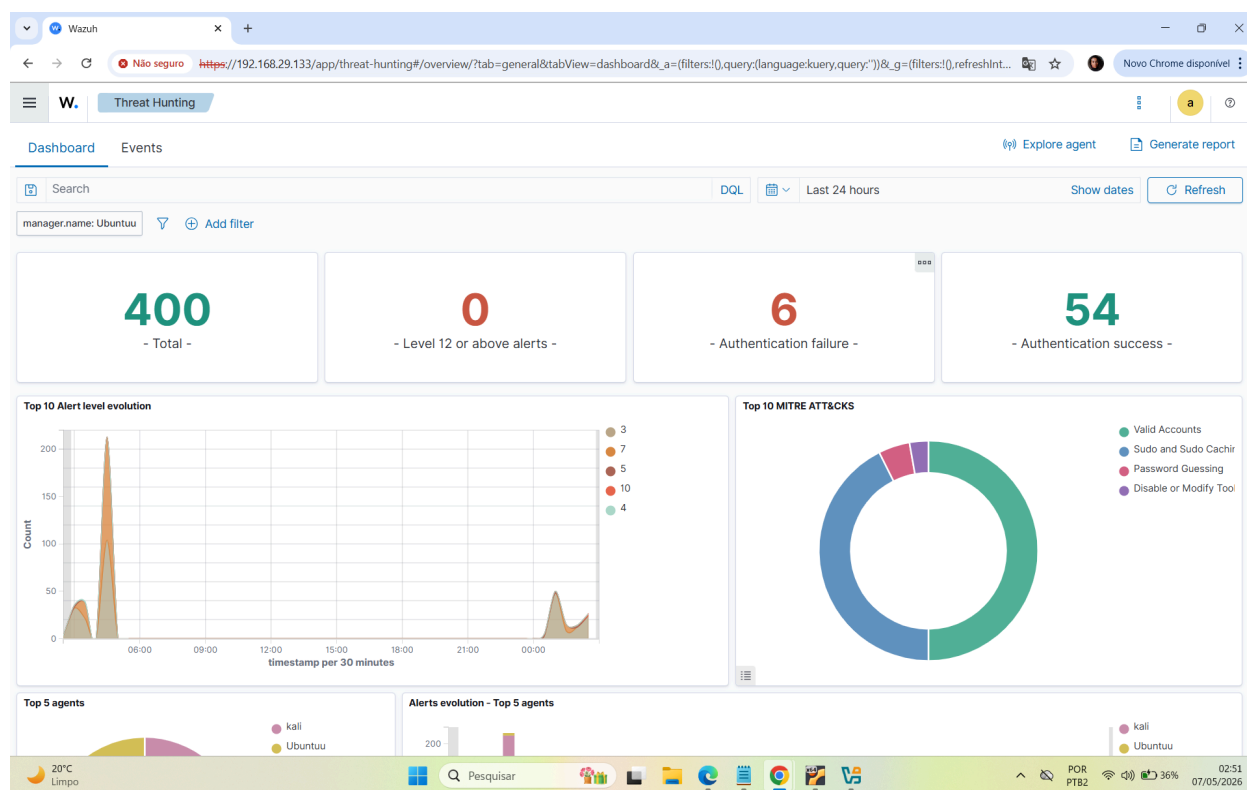


Figura 3 - Dashboard operacional do Wazuh apresentando correlação de eventos indicadores de autenticação e distribuição de técnicas associadas.

4. Conclusão e Aprendizados:

O desenvolvimento deste laboratório permitiu validar, na prática, a integração entre monitoramento de eventos de segurança e gestão de riscos em um ambiente controlado.

Durante os testes realizados, foi possível identificar serviços expostos, simular tentativas de autenticação e acompanhar a detecção automática dos eventos pelo Wazuh. Os registros coletados demonstraram como atividades aparentemente técnicas, como falhas de login via SSH, podem representar riscos relevantes para continuidade operacional e proteção de ativos críticos.

Sob a perspectiva de GRC, o laboratório possibilitou aplicar conceitos alinhados às normas da International Organization for Standardization:

- **ISO 27001** — estrutura de governança e gestão de controles
- **ISO 27002** — controles de autenticação, monitoramento e acesso
- **ISO 27005** — identificação, avaliação e tratamento de riscos

Como principal aprendizado, este projeto demonstrou que um ambiente SIEM não deve ser visto como apenas uma ferramenta de monitoramento, mas como um mecanismo de geração de evidências para suporte à tomada de decisão baseada em risco.

A experiência reforçou a importância de conectar eventos técnicos com impacto de negócio, aproximando operações de segurança da estratégia organizacional.

Este projeto representa a evolução de uma abordagem operacional para uma visão estratégica de cibersegurança, unindo monitoramento técnico, governança e gestão de riscos.